TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Volt Typhoon tied to "Silent Train" covert network used for zero-day exploitation, including Cisco SD-WAN

From **Cybersecurity Briefing 2026-10-29** · 2026-10-28 to 2026-10-29 (last 24 hours; Indiana sections cover 2026-10-24 to 2026-10-29) · Briefing generated 2026-10-29

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261029-05	1.0 · 2026-10-29 09:08 EDT	TLP:CLEAR	United States
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-10-28	2026-10-29	CVE-2026-20127 (CVSS 10.0), CVE-2022-20775, CVE-2026-16812, CVE-2025-8875, CVE-2025-8876, CVE-2024-39717	Nick Sturgeon

NATION-STATE / VULNERABILITY | CRITICAL

ACTIVELY EXPLOITED (HISTORICAL AND POST-DISCLOSURE); RELAY NETWORK REPORTED DISRUPTED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 2026-10-28, Lumen's Black Lotus Labs published research on Silent Train. It describes the network as a covert, multi-hop relay framework that the China-nexus group Volt Typhoon used from November 2023 for zero-day exploitation, credential theft, data theft and persistent access [S4] [S1]. Each chain started at a VPS outside the US, passed through compromised SOHO and IoT devices abroad, and exited through compromised US devices such as Netgear Orbi routers and FortiGate appliances. Chains averaged four to six hops, could be built in under two minutes, and were torn down after each session [S4] [S12]. Lumen ties the network to at least four confirmed zero-day campaigns and one likely one. Every one of them hit a management or control-plane product: Versa Director (CVE-2024-39717), N-able N-central (CVE-2025-8875/8876), Cisco Catalyst SD-WAN (CVE-2026-20127), Arista VeloCloud Orchestrator (CVE-2026-16812), and likely Quest KACE before its October 2025 fix [S1] [S4] [S3]. Lumen says it has sent hundreds of victim notifications and that the network is now disrupted [S4] [S1].

On the same day, Cisco Talos disclosed KeyDrift, a custom implant framework planted on Cisco Catalyst SD-WAN controllers after exploitation of CVE-2026-20127. CVE-2026-20127 is a CVSS 10.0 peering-authentication bypass that Cisco first disclosed and patched on 2026-02-25 [S5] [S7] [S8]. KeyDrift injects into the vdaemon control-plane process. Its PolyFlame module (libdssl.so) is a backdoor and relay that takes commands hidden inside SD-WAN control traffic. Its LittleFilch module (libcommon.so) collects what Talos assesses to be AES-256 IPsec data-plane keys and stages them, RSA-encrypted, in /var/tmp/vdaemon.bin. That would let an attacker who also captures traffic decrypt inter-site traffic [S5] [S2]. Talos tracks the operator as UAT-11473 and assesses with high confidence that its infrastructure 'overlaps considerably' with Silent Train. Talos does not say UAT-11473 is Volt Typhoon, and it does not explain how UAT-11473 relates to UAT-8616. UAT-8616 is the cluster Talos blamed in February 2026 for the original zero-day exploitation, which it traced back to at least 2023 [S5] [S6] [S2] [S3].

The briefing said the attribution could not be confirmed and mentioned an earlier UAT-8616 attribution. The primary sources settle part of that. Lumen independently attributes CVE-2026-20127 exploitation to Volt Typhoon, starting in late 2025 and continuing after disclosure [S4] [S3]. Talos's link from KeyDrift to Volt Typhoon rests only on shared infrastructure [S5]. UAT-8616, UAT-11473 and Volt Typhoon should therefore be treated as overlapping but not confirmed to be the same actor. Talos calls the KeyDrift activity historical and has not said when it happened or whether keys were actually exfiltrated [S2] [S5]. No hashes, IPs or domains have been published. The usable indicators are file paths, process-injection artifacts and log patterns on the SD-WAN control components [S5] [S6] [S7].

What to do: any organization running Cisco Catalyst SD-WAN (Manager, Controller or Validator, on-premises or Cisco-hosted) should confirm it is on a fixed release (20.9.8.2, 20.12.5.3/20.12.6.1, 20.15.4.2 or 20.18.2.1). Until then, restrict TCP 22 and 830 to known controllers. Then hunt for rogue vmanage-admin peers, unexplained root logins, downgrade-and-revert events and the KeyDrift files, because patching does not remove existing implants [S7] [S2] [S6]. If you find a compromise, rebuild the control components from

patched images, as CISA ED 26-03 requires of federal agencies, and plan to rotate SD-WAN keys and credentials [S9]. MSPs and owners of other management platforms (RMM, UEM, SD-WAN orchestrators) should treat this as a warning about control-plane exposure in general [S4].

Key judgments

VERY LIKELY · HIGH CONFIDENCE
Internet-reachable Cisco Catalyst SD-WAN control components that are still unpatched or on end-of-maintenance trains will very likely keep being exploited over the next 90 days, by Volt Typhoon-linked operators and by others, given KEV status, an EPSS of about 0.89 and public reporting of exploitation since 2023. [S6] [S7] [S10] [S11]

LIKELY · MODERATE CONFIDENCE
Some organizations that patched CVE-2026-20127 without forensic hunting likely still have implants or rogue peers on their SD-WAN controllers. Cisco warns that exploit artifacts can survive upgrades, and KeyDrift persists through modified runit scripts. [S2] [S5] [S7]

LIKELY · MODERATE CONFIDENCE
Volt Typhoon will likely rebuild or replace its covert relay capability, reusing SOHO, IoT and edge devices, within the next 6 to 12 months. Lumen observed exactly this after both KV-botnet disruptions. [S4] [S1]

LIKELY · MODERATE CONFIDENCE
More retrospective findings of management-plane compromises tied to Silent Train will likely surface from vendors or government partners in the coming months, especially among MSPs, telecoms and defense suppliers. Hundreds of victims have been notified and few technical indicators have been released so far. [S4] [S12] [S3]

UNLIKELY · LOW CONFIDENCE
Public reporting will unlikely establish within 90 days that UAT-8616, UAT-11473 and Volt Typhoon are a single actor. The current link rests on infrastructure overlap, and each vendor uses its own naming. [S5] [S6] [S2]

INDICATORS OF COMPROMISE

No hashes, IP addresses or domains have been published by Talos, Lumen or Cisco. The indicators below are host artifacts, log patterns and network behaviors from Talos's KeyDrift (2026-10-28) and UAT-8616 (2026-02-25) write-ups, Cisco's advisory, and Lumen's Silent Train report. Because the relay infrastructure was ephemeral and is now disrupted, network indicators would have had little lasting value even if they had been published.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/etc/sv/sshd/run`	Trojanized runit run script for the SSH service. It launches conf_sshd (the KeyDrift injector chain) before the real sshd starts.	REPORTED		[S5] [S2]
filepath	`/etc/sv/aaamgr/`	Fake aaamgr runit service seen on SD-WAN Validators (vBond) that runs the packed aaamgrd loader. Cisco's real aaamgr is a Python package and does not normally run as a compiled service.	REPORTED		[S5] [S2]
filename	`libdssl.so`	PolyFlame, the main KeyDrift module. It is injected into vdaemon and works as a TinyShell-style backdoor or intermediate C2 relay, tasked through SD-WAN control traffic.	REPORTED		[S5] [S2]
filename	`libcommon.so`	LittleFilch module. It hooks OpenSSL SSL_read inside vdaemon to pull control-session identifiers and assessed AES-256 data-plane key material (seen on vSmart/Controller).	REPORTED		[S5] [S2]
filename	`rsshd`	Ptrace-based injector that loads libdssl.so into vdaemon by PID.	REPORTED		[S5] [S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`conf_sshd`	Background loader shell script. It enumerates vdaemon PIDs, records injection output, and uses touch/chmod --reference for timestomping.	REPORTED		[S5] [S2]
filename	`aaamgrd`	Packed loader (RC4 packing, direct syscalls, anti-debugging) that decrypts and runs embedded PolyFlame. It also tampers with PAM configs on Validators.	REPORTED		[S5] [S2]
filepath	`/tmp/system-vdaemon`	File where conf_sshd records vdaemon process IDs.	REPORTED		[S5] [S2]
filepath	`/var/tmp/vdaemon.bin`	Encrypted staging file holding RSA-encrypted LittleFilch records (edge router IPs and 32-byte key fields).	REPORTED		[S5] [S2]
filepath	`/var/tmp/vdaemon.conf`	LittleFilch config with local and remote UDP endpoints for exfiltration. It is deleted after it is read, and Talos could not recover it. If you find it, treat it as high priority.	REPORTED		[S5] [S2]
filepath	`/rootfs.rw`	Writable overlay that the trojanized run script remounts as executable before launching the injector chain.	REPORTED		[S5]
command	`touch --reference=<legit_file> <implant_file>; chmod --reference=<legit_file> <implant_file>`	Timestomping and permission-copying pattern used by conf_sshd. The exact arguments were not published, so the placeholders are generic.	REPORTED		[S5] [S2]
other	`vdaemon process memory maps containing libdssl.so or libcommon.so`	Both modules are injected into vdaemon. Any non-Cisco shared object in /proc/<vdaemon_pid>/maps, or a non-zero TracerPid on vdaemon, suggests KeyDrift injection. This is inferred from Talos's description of the ptrace and linker interposition.	DERIVED		[S5]
other	`Accepted publickey for vmanage-admin (from unknown or unauthorized source IP) in /var/log/auth.log`	Cisco's exploitation check for CVE-2026-20127. Compare the source IPs with the System IPs configured in the Manager UI (Devices > System IP).	REPORTED		[S7] [S2]
other	`control-connection-state-change new-state:up peer-type:vmanage`	Peering event field Talos flags for validation. An unexpected vmanage peer can mean a rogue peer added through CVE-2026-20127.	REPORTED		[S6] [S7]
other	`system-login-change severity-level:minor ... user-name:"root"`	Notification of a root login on an SD-WAN component, seen after UAT-8616 escalated privileges.	REPORTED		[S6]
other	`Software upgrade not confirmed. Reverting to previous software version`	Log message associated with the downgrade-exploit-restore sequence used to reach root through CVE-2022-20775. 'Waiting for upgrade confirmation from user.' appears with it.	REPORTED		[S6]
filepath	`/home/root/.ssh/authorized_keys`	Check for SSH keys that cannot be accounted for, added for persistent root access.	REPORTED		[S6]
filepath	`/home/vmanage-admin/.ssh/authorized_keys`	Check for unauthorized keys on the internal high-privileged vmanage-admin account.	REPORTED		[S6]
filepath	`/home/root/.ssh/known_hosts`	Listed by Talos as an artifact to review for attacker pivots.	REPORTED		[S6]
other	`PermitRootLogin yes in /etc/ssh/sshd_config`	sshd configuration change seen in UAT-8616 activity.	REPORTED		[S6]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Cleared, truncated or 0-2 byte syslog, wtmp, lastlog, cli-history, bash_history; cli-history present for a user with no bash history`	Log-tampering indicators on SD-WAN components.	REPORTED		[S6]
http-request	`/../../`	Path traversal string tied to CVE-2022-20775 exploitation (privilege escalation after downgrade). Talos also lists the variant /\n&../\n&../.	REPORTED		[S6]
port	`22/tcp, 830/tcp`	Management ports (SSH, NETCONF) that Cisco says to restrict to known controllers and trusted hosts as an interim mitigation for CVE-2026-20127. NETCONF access is the post-exploitation capability.	REPORTED		[S7] [S8]
port	`8999/tcp`	Port used for a Chisel reverse tunnel in a Silent Train chain example.	REPORTED		[S4]
port	`2222/tcp, 8103/tcp, 14737/tcp, 8281/tcp`	Non-standard SSH (2222, 8103, 14737) and HTTP (8281) ports seen on Silent Train relay hops in Lumen's examples. Expect them on compromised SOHO, IoT and edge devices, not as victim-side IOCs.	REPORTED		[S4]
other	`Chisel and FRP (fast reverse proxy) binaries or processes on edge, SOHO or enterprise devices`	Open-source reverse tunneling tools used in later Silent Train variants.	REPORTED		[S4] [S1]
other	`Outbound UDP from SD-WAN Controller carrying DTLS 1.2 application-data style records to non-fabric endpoints`	LittleFilch can send RSA-encrypted data over UDP formatted like DTLS 1.2. Controller UDP traffic to anything other than known fabric peers is suspicious. Inferred from Talos's description; no endpoint is known.	DERIVED		[S5]
other	`Snort SIDs 65938, 65958 (CVE-2026-20127); 67387-67416 (Snort 2) and 7:44-7:73 (Snort 3) (KeyDrift)`	Talos detection coverage. The Snort 2 KeyDrift rules are disabled by default and must be enabled.	REPORTED	2026-10-28	[S5] [S2]
other	`Byte markers 40 03 06 (public IP), 40 0C 04 (peer system-IP), 05 01 0C 06 40 (32-byte key field)`	Patterns LittleFilch parses from decrypted OMP control messages. Useful for YARA-style memory or binary hunting of LittleFilch samples, not for network detection.	REPORTED		[S5]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

Volt Typhoon operators reached targets through Silent Train, a set of short-lived chains: a foreign VPS, then compromised foreign SOHO and IoT devices, then compromised US exit devices. The chains were built with temporary SSH services, keys and live-off-the-land tools, later supplemented by Chisel and FRP reverse tunnels. Sessions ran on weekday working hours in China time and were followed by full artifact cleanup [S4] [S12]. They aimed zero-days at management and control-plane platforms so that one compromise gave administrative reach into downstream customers and networks without classic lateral movement [S4]. On Cisco Catalyst SD-WAN, the attacker abuses CVE-2026-20127 to pass peering authentication and log in as the internal vmanage-admin account, adds rogue control-connection peers, and can manipulate the fabric over NETCONF [S7] [S8] [S6]. In UAT-8616 activity, the attacker then downgraded the software, exploited CVE-2022-20775 for root, restored the original version and cleared logs [S6]. The KeyDrift implant (UAT-11473) persists through trojanized runit scripts. It is ptrace-

injected into vdaemon, takes commands hidden in control traffic, and harvests data-plane AES keys for RSA-encrypted staging or UDP exfiltration [S5] [S2].

Threat actor

Volt Typhoon · also tracked as UAT-11473 (Talos; KeyDrift operator, infrastructure overlap with Silent Train), UAT-8616 (Talos; CVE-2026-20127 exploitation cluster, relationship not stated)

Attribution confidence: Moderate · **Motivation:** Espionage and strategic pre-positioning for possible disruption during an Indo-Pacific crisis · **Suspected origin:** People's Republic of China (state-sponsored per US government reporting cited in coverage)

Lumen attributes Silent Train and the four or five zero-day campaigns to Volt Typhoon. Talos assesses with high confidence only an infrastructure overlap between UAT-11473 and Silent Train, and does not equate them [S5]. The aliases listed are overlapping clusters, not confirmed synonyms. Talos dates UAT-8616 activity to at least 2023, while Lumen dates Volt Typhoon's exploitation of CVE-2026-20127 to late 2025. That gap suggests either more than one operator or incomplete visibility.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1584.008 Compromise Infrastructure: Network Devices	Exploited exposed web interfaces on SOHO routers, IoT and enterprise edge devices (TP-Link, Netgear Orbi, Intelbras, Zyxel, FortiGate and others) and enrolled them as relay hops with fixed roles. [S4] [S1]	Monitor owned edge and SOHO devices for unknown SSH listeners on non-standard ports, new authorized keys, and Chisel/FRP processes.
Command and Control	T1090.003 Proxy: Multi-hop Proxy	Chains of four to six hops (foreign VPS, foreign SOHO/IoT, US exit node) were rebuilt for each session to defeat geofencing and IP reputation. [S4] [S12]	Geo or reputation blocks are not enough. Alert on admin logins to management platforms from residential or SOHO IP space and from sources that are not on the allowlist.
Command and Control	T1572 Protocol Tunneling	Later variants used Chisel and FRP reverse tunnels (for example, port 8999). [S4]	Hunt for Chisel/FRP binaries and long-lived outbound tunnels from edge or enterprise devices.
Initial Access	T1190 Exploit Public-Facing Application	Zero-day exploitation of management and control-plane products: Cisco Catalyst SD-WAN (CVE-2026-20127), Versa Director (CVE-2024-39717), N-able N-central (CVE-2025-8875/8876), VeloCloud Orchestrator (CVE-2026-16812), and likely Quest KACE. [S4] [S1] [S7] [S6]	Restrict management interfaces. Watch for anomalous auth and peering events and unexpected admin API calls. Deploy vendor IDS signatures (Snort 65938/65958).
Initial Access	T1199 Trusted Relationship	Management platforms (RMM, UEM, SD-WAN orchestrators) were abused to reach downstream customer devices without lateral movement. [S4]	Review management-platform audit logs for unusual remote file transfers, script runs and configuration pushes, especially off-hours.
Persistence	T1098.004 Account Manipulation: SSH Authorized Keys	SSH keys added for root and vmanage-admin, and PermitRootLogin enabled on SD-WAN components. [S6]	Baseline and diff authorized_keys and sshd_config on SD-WAN components.
Defense Evasion	T1078 Valid Accounts	The authentication bypass lets the attacker log in as the internal high-privileged vmanage-admin account; Lumen also reports stolen credentials reused on return visits. [S7] [S8] [S12]	Alert on Accepted publickey for vmanage-admin from sources other than configured System IPs.
Privilege Escalation	T1068 Exploitation for Privilege Escalation	CVE-2022-20775 path traversal used to gain root after a software downgrade. [S6] [S9]	Look for traversal strings in CLI history and unexpected downgrade-and-revert log messages.

Tactic	Technique	Procedure observed	Detection opportunity
Defense Evasion	T1601.002 Modify System Image: Downgrade System Image	SD-WAN software downgraded to a version vulnerable to CVE-2022-20775, then restored to hide the change. [S6]	Alert on version changes and reboots outside maintenance windows. Watch for 'Software upgrade not confirmed. Reverting...' messages.
Persistence	T1037 Boot or Logon Initialization Scripts	Modified runit run scripts (/etc/sv/sshd/run, /etc/sv/aaamgr/) launch KeyDrift before legitimate services. [S5]	Hash and diff /etc/sv/*/run against known-good images or admin-tech baselines.
Persistence	T1543 Create or Modify System Process	Fake compiled aaamgr service created on Validators. [S5] [S2]	A compiled aaamgrd binary under /etc/sv/aaamgr/ is anomalous.
Defense Evasion	T1036.004 Masquerading: Masquerade Task or Service	The implant masquerades as Cisco's aaamgr and sshd services. [S5]	Compare service binaries against Cisco-signed packages.
Defense Evasion	T1055.008 Process Injection: Ptrace System Calls	rsshd ptrace-injects libdssl.so into vdaemon by PID. [S5]	Look for non-Cisco shared objects in vdaemon memory maps and a non-zero TracerPid.
Defense Evasion	T1574.006 Hijack Execution Flow: Dynamic Linker Hijacking	PolyFlame interposes socket, DTLS, dlopen/dlsym and mprotect functions in vdaemon. [S5]	Memory forensics of vdaemon. Talos Snort rules cover the network side.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	PolyFlame command 0x100 runs commands through /bin/sh -c; conf_sshd is a shell loader. [S5]	Process lineage: /bin/sh spawned by vdaemon is anomalous.
Defense Evasion	T1027.002 Obfuscated Files or Information: Software Packing	aaamgrd is RC4-packed and uses direct syscalls. [S5]	Entropy and packing checks on binaries outside Cisco packages.
Defense Evasion	T1497.001 Virtualization/Sandbox Evasion: System Checks	Anti-debugging via a TracerPid check and a date-hash gate before the implant runs. [S5]	Relevant mainly to malware analysis.
Defense Evasion	T1070.006 Indicator Removal: Timestomp	touch --reference and chmod --reference copy metadata from legitimate files onto implant files. [S5] [S2]	Do not rely on mtime. Compare file hashes against golden images.
Defense Evasion	T1070.002 Indicator Removal: Clear Linux or Mac System Logs	syslog, wtmp, lastlog, cli-history and bash_history cleared or truncated. Silent Train operators also removed all session artifacts. [S6] [S4]	Forward logs off-box in real time and alert on log gaps or 0-2 byte log files.
Credential Access	T1040 Network Sniffing	LittleFilch hooks SSL_read in vdaemon to capture decrypted OMP messages containing edge router IPs and AES-256 data-plane key material. [S5] [S2]	Check for /var/tmp/vdaemon.bin and injected libraries.
Command and Control	T1573.001 Encrypted Channel: Symmetric Cryptography	PolyFlame uses AES and is tasked in-band within SD-WAN control traffic, with no hardcoded C2. [S5]	Talos Snort SIDs 67387-67416 / 7:44-7:73.
Exfiltration	T1048 Exfiltration Over Alternative Protocol	LittleFilch can send RSA-encrypted records over UDP formatted like DTLS 1.2 to endpoints from vdaemon.conf. [S5] [S2]	Egress-filter SD-WAN controllers to known fabric peers only and alert on other UDP flows.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Cisco SD-WAN: vmanage-admin public key logins from unexpected sources `SPLUNK SPL`

```
index=network sourcetype=syslog (host=*vsmart* OR host=*vmanage* OR host=*vbond* OR host=*sdwan*) "Accepted publickey for vmanage-
admin"
| rex "from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| search NOT [| inputlookup sdwan_system_ips.csv | fields src_ip]
| stats count min(_time) as first_seen max(_time) as last_seen by host src_ip
| convert ctime(first_seen) ctime(last_seen)
```

Requires SD-WAN control components to forward /var/log/auth.log through syslog. Fill sdwan_system_ips.csv with the System IPs and public IPs of legitimate controllers and managers (Manager UI > Devices). Adjust the host filters to your naming.

Cisco SD-WAN: root login, downgrade-revert, and new vmanage peers `SPLUNK SPL`

```
index=network sourcetype=syslog (host=*vsmart* OR host=*vmanage* OR host=*vbond* OR host=*sdwan*) ("system-login-change" "root") OR
"Software upgrade not confirmed" OR "Waiting for upgrade confirmation from user" OR ("control-connection-state-change" "new-state:up"
"peer-type:vmanage")
| eval indicator=case(searchmatch("system-login-change"),"root_login", searchmatch("Software upgrade not confirmed") OR
searchmatch("Waiting for upgrade confirmation"),"downgrade_revert", true(),"vmanage_peer_up")
| stats count values(indicator) as indicators min(_time) as first_seen by host
| where mvcount(indicators)>=1
```

Correlate vmanage_peer_up events with change windows and known Manager IPs. A root_login together with a downgrade_revert on the same host should be escalated right away.

KeyDrift artifacts on Linux-based SD-WAN components `SIGMA`

```
title: Cisco SD-WAN KeyDrift Artifact Creation
id: 0f3c9a52-6d1e-4b8a-9c77-3a1e5d2b7f10
status: experimental
description: Detects creation of file names and paths reported by Cisco Talos for the KeyDrift implant framework on Cisco Catalyst SD-
WAN controllers.
references:
  - https://blog.talosintelligence.com/uat-11473-keydrift/
logsource:
  product: linux
  category: file_event
detection:
  selection_paths:
    TargetFilename|endswith:
      - '/tmp/system-vdaemon'
      - '/var/tmp/vdaemon.bin'
      - '/var/tmp/vdaemon.conf'
      - '/libdssl.so'
      - '/libcommon.so'
      - '/rsshd'
      - '/conf_sshd'
      - '/aaamgrd'
  selection_sv:
    TargetFilename|startswith: '/etc/sv/aaamgr/'
  condition: selection_paths or selection_sv
falsepositives:
  - Unlikely; legitimate Cisco libraries may share generic names, so verify the location and hash against Cisco images
level: critical
tags:
  - attack.persistence
  - attack.t1037
  - attack.t1055.008
```

Most SD-WAN appliances cannot run an EDR or auditd agent. In practice, run these checks against admin-tech bundles or forensic disk images, or ask Cisco TAC to check. The libcommon.so name is generic, so confirm location and hash.

Inbound SSH/NETCONF to SD-WAN control components from non-allowlisted sources `SURICATA`

```
alert tcp !$SDWAN_TRUSTED any -> $SDWAN_CONTROLLERS [22,830] (msg:"LOCAL Possible unauthorized SSH/NETCONF access to Cisco SD-WAN control component"; flow:to_server; flags:S,12; threshold:type limit, track by_src, count 1, seconds 3600; classtype:attempted-admin; sid:9100001; rev:1;)
```

Define SDWAN_CONTROLLERS (Manager, Controller and Validator IPs) and SDWAN_TRUSTED (peer controllers, jump hosts) in suricata.yaml. This rule monitors whether Cisco's interim port-restriction mitigation is working, and it complements Talos Snort SIDs 65938/65958 and 67387-67416.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Cisco Catalyst SD-WAN Controller (vSmart), Manager (vManage), Validator (vBond): on-prem, Cisco Hosted Cloud, Cisco Managed, FedRAMP	All releases before the fixed builds, regardless of configuration (Validator added to the advisory 2026-06-16)	20.9.8.2; 20.12.5.3 or 20.12.6.1; 20.15.4.2; 20.18.2.1. Releases before 20.9 must migrate. 20.11/20.13/20.14/20.16 are end of software maintenance	CVE-2026-20127	10.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)	0.89294 (99.78th percentile, 2026-10-28)	Yes (added 2026-02-25)	2026-02-27
Cisco Catalyst SD-WAN (CLI privilege escalation used after downgrade)	Versions vulnerable to CVE-2022-20775 (reached through attacker-forced downgrade)	Current fixed releases; prevent unauthorized downgrades	CVE-2022-20775	Not confirmed in sources reviewed	Not retrieved	Yes (added 2026-02-25)	2026-02-27
Arista VeloCloud Orchestrator (On-Prem)	Not detailed in sources reviewed	See vendor advisory (not reviewed)	CVE-2026-16812	Not confirmed in sources reviewed	0.01001 (62.7th percentile, 2026-10-28)	Yes (added 2026-07-27)	2026-07-30

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
N-able N-central	Not detailed in sources reviewed	See vendor advisory (not reviewed)	CVE-2025-8875, CVE-2025-8876	Not confirmed in sources reviewed	0.01899 / 0.03448 (2026-10-28)	Yes (CVE-2025-8876 added 2025-08-13; CVE-2025-8875 not checked)	2025-08-20
Versa Director	Not detailed in sources reviewed	See vendor advisory (not reviewed)	CVE-2024-39717	Not confirmed in sources reviewed	0.03987 (90.5th percentile, 2026-10-28)	Not checked	N/A
Quest KACE (UEM)	Versions before Quest's October 2025 updates (likely zero-day, moderate confidence per Lumen)	Quest October 2025 updates	None assigned in sources reviewed	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Inventory every Cisco Catalyst SD-WAN Manager, Controller and Validator (yours and clients'). Confirm the running release against Cisco's fixed-release table and upgrade any that are behind, migrating off end-of-maintenance trains. `IT OPS` [S7] [S2]
- Until patched, restrict TCP 22 and 830 on self-hosted SD-WAN control components to known controller IPs and trusted management hosts using ACLs or firewall rules. Cisco-hosted cloud already has these restrictions. `IT OPS` [S7]
- Run 'request admin-tech' on each control component before changing anything. Preserve /home and externally stored syslogs, and take disk and memory snapshots of virtual instances, so evidence survives the upgrade. `SOC` [S7] [S9]
- Hunt /var/log/auth.log for 'Accepted publickey for vmanage-admin' from unknown IPs. Validate every control-connection peering event (especially peer-type vmanage) against System IPs and maintenance windows, and look for root logins, downgrade-revert messages and log gaps. `SOC` [S7] [S6]
- Check for KeyDrift artifacts (/etc/sv/aaamgr/, modified /etc/sv/sshd/run, libdssl.so, libcommon.so, rsshd, conf_sshd, aaamgrd, /tmp/system-vdaemon, /var/tmp/vdaemon.bin). Enable Talos Snort 2 SIDs 67387-67416 (disabled by default) or Snort 3 SIDs 7:44-7:73, plus 65938/65958. `SOC` [S5] [S2]

Short term (1–7 days)

- If any indicator is found, open incident response and a Cisco TAC case. Rebuild Manager, Controller and Validator from patched images and migrate edges to them rather than cleaning in place, following the ED 26-03 approach. `IT OPS` [S9] [S5] [S7]
- On compromised fabrics, rotate SD-WAN certificates, local and admin credentials and SSH keys, and force regeneration of data-plane keys. Assume past inter-site traffic may be decryptable if it was captured. Sources do not give explicit key-rotation guidance, so confirm with Cisco TAC. `IT OPS` [S2] [S5]

- Apply the Cisco Catalyst SD-WAN hardening guide and the CISA ED 26-03 hunt and hardening supplement, even for non-federal environments. `IT OPS` [S9] [S5] [S6]
- Review all management and control-plane platforms (RMM such as N-able N-central, UEM such as Quest KACE, Versa and VeloCloud orchestrators, network management systems) for patch level, internet exposure and anomalous admin activity, including logins between 09:00 and 22:00 China Standard Time on weekdays, which Lumen observed. `SOC` [S4] [S1]
- Notify executive leadership and affected clients of exposure findings. Brief them that attribution is provisional (Volt Typhoon per Lumen; infrastructure overlap only per Talos). `LEADERSHIP` [S4] [S5]

Long term

- Move all management interfaces (SD-WAN, RMM, UEM, firewalls) behind VPN, jump hosts or a dedicated management network. Remove direct internet exposure. `IT OPS` [S4]
- Centralize SD-WAN and management-platform logs off-box with longer retention (at least 12 months) so that on-box log wiping does not erase evidence. `SOC` [S4] [S9] [S6]
- Set a patch SLA of 72 hours or less for critical flaws in internet-facing control-plane and management products. Track vendor end-of-maintenance dates. `LEADERSHIP` [S4] [S7]
- Assess the trust relationships through which a compromised management platform could reach clients or partners, and segment or limit the privileges of those paths. `LEADERSHIP` [S4]
- Replace end-of-life SOHO routers and IoT devices at small offices and remote workers, since devices of this kind served as Silent Train relay nodes. `IT OPS` [S4] [S1]

Workarounds & compensating controls

- Where patching is delayed, enforce ACLs on ports 22/830 and alert on any inbound connection from a source not on the allowlist (see the Suricata rule). `IT OPS` [S7]
- Filter egress from SD-WAN controllers to known fabric peers and Cisco services only, to block LittleFilch-style UDP exfiltration. `IT OPS` [S5]
- Where available, add an application-layer encryption layer (TLS) for sensitive inter-site traffic so that stolen SD-WAN IPsec keys alone do not expose the data. `IT OPS` [S5]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Volt Typhoon Used Covert Silent Train Network in Four Zero-Day Exploitation Campaigns
Published 2026-10-28 · `B2` Usually reliable, probably true
Briefing source (via front page). Summarizes the Lumen report and supplies the Versa CVE ID.

[S2] The Hacker News: Hackers Exploited Cisco SD-WAN Flaw to Plant Malware Built to Steal Encryption Keys
Published 2026-10-29 · `B2` Usually reliable, probably true
Briefing source. Detailed KeyDrift summary and notes gaps in Talos remediation advice.

[S3] SecurityWeek: Cisco SD-WAN Zero-Day Exploitation Tied to Volt Typhoon's 'Silent Train' Network
Published 2026-10-29 · `B2` Usually reliable, probably true
Briefing source (via front page). Links the Talos and Lumen reports and notes Lumen does not mention KeyDrift.

[S4] Lumen Black Lotus Labs: Silent Train: uncovering Volt Typhoon's operational framework for zero-day exploitation and strategic access
Published 2026-10-28 · `A2` Completely reliable, probably true
Primary research on Silent Train. Publication date is from press coverage. No hashes, IPs or domains published.

[S5] Cisco Talos: UAT-11473 / KeyDrift: Cisco Catalyst SD-WAN implant framework
Published 2026-10-28 · `A2` Completely reliable, probably true
Primary malware analysis. Source of the host artifacts, ATT&CK mapping and Snort SIDs. Attribution is to infrastructure overlap only.

[S6] Cisco Talos: UAT-8616 exploitation of Cisco Catalyst SD-WAN (CVE-2026-20127)
Published 2026-02-25 · **A1** Completely reliable, confirmed by other sources
Original zero-day exploitation report. Corroborated by Cisco PSIRT, CISA ED 26-03 and KEV.

[S7] Cisco PSIRT: Cisco Catalyst SD-WAN Controller Authentication Bypass Vulnerability (cisco-sa-sdwan-rpa-EHchtZk)
Published 2026-02-25 · **A1** Completely reliable, confirmed by other sources
Vendor advisory, last updated 2026-10-28 (v2.1). Fixed releases, interim mitigation, IoC checks. Credits ASD's ACSC.

[S8] MITRE CVE / CVE.org: CVE-2026-20127 record
Published 2026-02-25 · **A1** Completely reliable, confirmed by other sources
CVSS 3.1 10.0, CWE-287, NETCONF post-exploitation capability.

[S9] CISA: ED 26-03: Mitigate Vulnerabilities in Cisco SD-WAN Systems
Published 2026-02-25 · **A1** Completely reliable, confirmed by other sources
Emergency directive (updated 2026-03-11). Rebuild-from-patched-images requirement after root compromise.

[S10] CISA: Known Exploited Vulnerabilities Catalog entries (CVE-2026-20127, CVE-2022-20775, CVE-2026-16812, CVE-2025-8876)
Published 2026-02-25 · **A1** Completely reliable, confirmed by other sources
KEV dates added and due dates.

[S11] FIRST: EPSS scores for CVE-2026-20127, CVE-2026-16812, CVE-2025-8875, CVE-2025-8876, CVE-2024-39717
Published 2026-10-28 · **A2** Completely reliable, probably true
Model-based exploitation probability scores, not observations.

[S12] ZERO DAY (Kim Zetter): Silent Train: Volt Typhoon's sophisticated infection chain into US targets exposed
Published 2026-10-28 · **B2** Usually reliable, probably true
Interview with Black Lotus Labs researcher Mike Horka. Adds detail on document exfiltration and return visits.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2023-01-01	Approximate. Talos says UAT-8616 malicious activity on Cisco SD-WAN dates back to at least 2023 (exact date unknown).	[S6]
2023-11-01	Approximate (November 2023). Lumen first observes Silent Train activity, shortly before the first KV-botnet disruption.	[S4] [S1]
2024-01-31	Approximate (late January 2024). Second KV-botnet disruption, after which Silent Train activity surges on ephemeral infrastructure.	[S1]
2024-08-01	Approximate (mid-2024). Black Lotus Labs publicly documents Versa Director zero-day exploitation (CVE-2024-39717).	[S4] [S1]
2025-01-01	Approximate (early 2025). Silent Train evolves into a hybrid design with enterprise final hops kept for one to three months.	[S4] [S1]
2025-08-13	CISA adds N-able N-central CVE-2025-8876 to KEV.	[S10]
2025-10-01	Approximate (October 2025). Quest releases KACE updates. Lumen sees suspected zero-day activity decline afterward.	[S4] [S1]

Date	Event	Source
2025-12-01	Approximate (late 2025). Lumen reports Volt Typhoon exploiting the Cisco Catalyst SD-WAN flaw (later CVE-2026-20127).	[S4] [S3]
2026-02-25	Cisco discloses and patches CVE-2026-20127. Talos attributes exploitation to UAT-8616. CISA issues ED 26-03 and adds CVE-2026-20127 and CVE-2022-20775 to KEV.	[S7] [S6] [S9] [S10]
2026-03-11	CISA updates ED 26-03 with log-sharing (CLAW) requirements.	[S9]
2026-06-16	Cisco adds SD-WAN Validator to the affected products in the advisory.	[S2]
2026-07-27	CISA adds VeloCloud Orchestrator CVE-2026-16812 to KEV.	[S10]
2026-10-28	Lumen publishes Silent Train research. Talos publishes the UAT-11473/KeyDrift analysis and Snort rules. Cisco updates its advisory to v2.1.	[S4] [S5] [S7] [S1]
2026-10-29	The Hacker News and SecurityWeek report the KeyDrift and Silent Train infrastructure link.	[S2] [S3]

Relevance to Indianapolis, Indiana & managed clients

Cisco Catalyst SD-WAN is widely used to connect multi-site organizations of the kinds common in central Indiana: hospital and clinic networks, school districts and universities, county and municipal governments, and manufacturers and logistics firms with several plants or distribution centers. Any of these that run self-hosted Manager, Controller or Validator instances should treat the patch-and-hunt steps as urgent, because KeyDrift targets the keys that protect traffic between sites. Lumen's victim list includes MSPs and IT providers, and the actor's targeting of RMM and UEM platforms (N-able N-central, Quest KACE) matters directly to managed IT service clients. A compromised management platform gives the attacker reach into every downstream customer, so MSP tooling, admin interfaces and logging should be reviewed now. Indiana was not named as a focus state (Hawaii, California and Texas were). However, the defense industrial base, aerospace suppliers, utilities, rail and logistics operators, and universities with defense research or ROTC ties in Indiana fit the sector profile Lumen describes. Small and mid-size businesses and remote workers are relevant in another way: aging SOHO routers and IoT devices of the kinds abused as Silent Train relay hops (TP-Link, Netgear, Zyxel and others) are common in local small offices, and replacing end-of-life units lowers the chance that local equipment is used against others. No Indiana-specific victims have been reported.

Intelligence gaps

- When the KeyDrift activity happened and whether any key material was actually exfiltrated (Talos calls it historical and gives no dates).
- How UAT-8616, UAT-11473 and Volt Typhoon relate. Talos reports infrastructure overlap only, and the start-of-exploitation dates differ (Talos: at least 2023; Lumen: late 2025).
- No file hashes, C2 endpoints or relay IPs have been published. Talos could not recover vdaemon.conf, so the exfiltration destination is unknown.
- Whether upgrading removes KeyDrift from an already-compromised device, and whether Cisco recommends rotating keys or certificates after compromise.
- Number, sectors and locations of victims beyond Lumen's high-level statements, and whether any Indiana organizations received Black Lotus Labs notifications.
- CVSS scores and fixed versions for CVE-2026-16812, CVE-2025-8875/8876 and CVE-2024-39717 were not verified in this report. The Quest KACE flaw has no CVE in the sources reviewed.
- Watch for follow-on joint government advisories (CISA/NSA/FBI, ASD ACSC, NCSC), Lumen IOC releases, and any reports of Silent Train being rebuilt.

Other notes

- The briefing's claim of an 'earlier Talos attribution to UAT-8616' is accurate. Talos named UAT-8616 for CVE-2026-20127 exploitation in February 2026 and named UAT-11473 for KeyDrift in October 2026. These are separate clusters whose relationship Talos has not stated.
- Lumen's report does not mention KeyDrift or UAT-11473. The connection comes only from Talos's infrastructure-overlap assessment [S3] [S5].
- Lumen's page lists VeloCloud Orchestrator as a zero-day later assigned CVE-2026-16812. The Hacker News lists the four confirmed campaigns as Versa, N-able, Cisco and VeloCloud, with Quest KACE as the likely fifth. The Versa CVE ID (CVE-2024-39717) comes from The

Hacker News; the Lumen page did not show it in the reviewed content.

- Some secondary coverage (not cited) reports a public proof-of-concept for CVE-2026-20127. This was not verified and no PoC was fetched.
- Cisco credits the Australian Signals Directorate's ACSC with reporting CVE-2026-20127. Cisco also warned in March 2026 of exploitation of related SD-WAN flaws CVE-2026-20128 and CVE-2026-20122 (secondary reporting, not verified here).
- Lumen points defenders to CISA/partner advisories AA24-038A and AA26-113A on Volt Typhoon and China-nexus covert networks.
- SecurityWeek on 2026-10-29 also reported a separate, unrelated Cisco ASA/FTD Remote Access SSL VPN zero-day (denial of service). Do not conflate it with this item.

CTI-20261029-05 v1.0 · Generated 2026-10-29 09:08 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.